

AuthzLedger / selective retest evidence

Assessment

Title

AuthzLedger / selective retest evidence

Assessment ID

demo-c-selective100

Reviewer

Synthetic demonstration runner

Period

Retained execution timestamps

Snapshot

7d076d32f38cc82654d30ee0650b22c0dc83864ead46089e383f01bd20772af3

Renderer

assessment-html-pdf-v1-reportlab-4.4.9-dejavu-2.37

Executive summary

Summary

100 baseline requests; 7 selected checks plus 3 fresh prerequisite controls; 90 cases remain not_retested.

Finding status

{"candidate": 0, "confirmed": 0, "rejected": 0, "retest_pending": 0, "retest_verified": 7}

Scope and methodology

Scope

http://127.0.0.1:46833

Method

Explicit rules, source-bound requests and valid controls. Evidence remains local; observations are reviewed at their recorded verification level.

Coverage

[{"comparison_sha256": "6665988aa0408f92d465ae23a549ada474d43332315f368f4839bc28ceaf3bac", "dependency_cases": 3, "not_retested_cases": 90, "retested_cases": 10, "selected_cases": 7, "source_cases": 100}]

Selective retest: seven declared views of one synthetic resource

Finding ID

finding-1a3df35e5a24cf5ba97950c8

Status

retest_verified

Execution record status

rejected

Interpretation

satisfied

Category

authorization_rule_violation

Rule digest

d4302c1e4ea6e69db715cb1860dd1a2487aa1a52343172d0cb7609bf7cf5aabb

Resource

invoice-A

Identity

peer

Case

target-2

Reproduction

GET /invoice/A?view=2 as peer; execute controls before this case. Use the retained source contract and environment/session credential references.

Expected checks

```
{"json_absent": ["/marker"], "status": [403]}
```

Observation

```
[{"body_complete": true, "controls_valid": true, "interpretation": "satisfied", "status": 403, "verification_level": "captured_inputs_replayed"}]
```

Controls

actor, negative, owner

Evidence

862e6caf682ffbd45c98144ec7c310f3d8cd643d7f0a0f093a66353ad162a93

Source report root

6f3bc05804641b66134abf65c356f5c08011a3c1d7a9eda330b7d46196e82751

Finding record digest

67941dc125debe2b71cb76113fab30068352545d7b82cf95c726d7c2558f50ad

Verification level

captured_inputs_replayed

Impact

Limited to the explicitly evaluated predicate; business impact requires review.

Remediation

Enforce the configured rule at the resource and response boundary; rerun this experiment with fresh controls.

Business risk

Not assessed by reviewer

CVSS 4.0

not_scored; vector: not supplied

Retest

```
[{"baseline_root": "9a9ea83b31031ee4c66bef9737ab671b151b69abe38eafd37d4de2c33434c3a3",
"case_id": "target-2", "comparison_digest":
"a3b207ec41722d49915c95384fa89d59f159873df4f119509a97c966e6b0550b", "comparison_sha256":
"6665988aa0408f92d465ae23a549ada474d43332315f368f4839bc28ceaf3bac", "current_root":
"6f3bc05804641b66134abf65c356f5c08011a3c1d7a9eda330b7d46196e82751", "finding_status":
"fix_verified", "status": "resolved_check"}]
```

Standards mapping

No requirement-level mapping reviewed.

Limitations

Remote response authenticity is not established by local signing.

Only selected oracle inputs are replayed; their projection from the omitted raw body remains signer-attested.

Selective retest: seven declared views of one synthetic resource

Finding ID

finding-3ace0e8f12001e15834c8592

Status

retest_verified

Execution record status

rejected

Interpretation

satisfied

Category

authorization_rule_violation

Rule digest

d4302c1e4ea6e69db715cb1860dd1a2487aa1a52343172d0cb7609bf7cf5aabb

Resource

invoice-A

Identity

peer

Case

target-1

Reproduction

GET /invoice/A?view=1 as peer; execute controls before this case. Use the retained source contract and environment/session credential references.

Expected checks

{"json_absent": ["/marker"], "status": [403]}

Observation

[{"body_complete": true, "controls_valid": true, "interpretation": "satisfied", "status": 403, "verification_level": "captured_inputs_replayed"}]

Controls

actor, negative, owner

Evidence

da8595b5d2c3d261c25d960e6454866bb3a554431855c38612b53ee94d730fee

Source report root

6f3bc05804641b66134abf65c356f5c08011a3c1d7a9eda330b7d46196e82751

Finding record digest

06dd793ab73244f099afd23984dae711e59f55ed4e54678cb6fab4750627b28e

Verification level

captured_inputs_replayed

Impact

Limited to the explicitly evaluated predicate; business impact requires review.

Remediation

Enforce the configured rule at the resource and response boundary; rerun this experiment with fresh controls.

Business risk

Not assessed by reviewer

CVSS 4.0

not_scored; vector: not supplied

Retest

[{"baseline_root": "9a9ea83b31031ee4c66bef9737ab671b151b69abe38eafd37d4de2c33434c3a3", "case_id": "target-1", "comparison_digest": "a3b207ec41722d49915c95384fa89d59f159873df4f119509a97c966e6b0550b", "comparison_sha256": "6665988aa0408f92d465ae23a549ada474d43332315f368f4839bc28ceaf3bac", "current_root": "6f3bc05804641b66134abf65c356f5c08011a3c1d7a9eda330b7d46196e82751", "finding_status": "fix_verified", "status": "resolved_check"}]

Standards mapping

No requirement-level mapping reviewed.

Limitations

Remote response authenticity is not established by local signing.

Only selected oracle inputs are replayed; their projection from the omitted raw body remains signer-attested.

Selective retest: seven declared views of one synthetic resource

Finding ID

finding-3b808dceafc6e1325bf3b601

Status

retest_verified

Execution record status

rejected

Interpretation

satisfied

Category

authorization_rule_violation

Rule digest

d4302c1e4ea6e69db715cb1860dd1a2487aa1a52343172d0cb7609bf7cf5aabb

Resource

invoice-A

Identity

peer

Case

target-3

Reproduction

GET /invoice/A?view=3 as peer; execute controls before this case. Use the retained source contract and environment/session credential references.

Expected checks

{"json_absent": ["/marker"], "status": [403]}

Observation

[{"body_complete": true, "controls_valid": true, "interpretation": "satisfied", "status": 403, "verification_level": "captured_inputs_replayed"}]

Controls

actor, negative, owner

Evidence

ed9f418c004cd4cbb70ea58a8b407ccef9c0857b44d88f04111fefa891e334c9

Source report root

6f3bc05804641b66134abf65c356f5c08011a3c1d7a9eda330b7d46196e82751

Finding record digest

f597bda23fb41ab7f8d557fdcf2e907dc1164aaff39db26c74c81a14da566918

Verification level

captured_inputs_replayed

Impact

Limited to the explicitly evaluated predicate; business impact requires review.

Remediation

Enforce the configured rule at the resource and response boundary; rerun this experiment with fresh controls.

Business risk

Not assessed by reviewer

CVSS 4.0

not_scored; vector: not supplied

Retest

```
[{"baseline_root": "9a9ea83b31031ee4c66bef9737ab671b151b69abe38eafd37d4de2c33434c3a3",
"case_id": "target-3", "comparison_digest":
"a3b207ec41722d49915c95384fa89d59f159873df4f119509a97c966e6b0550b", "comparison_sha256":
"6665988aa0408f92d465ae23a549ada474d43332315f368f4839bc28ceaf3bac", "current_root":
"6f3bc05804641b66134abf65c356f5c08011a3c1d7a9eda330b7d46196e82751", "finding_status":
"fix_verified", "status": "resolved_check"}]
```

Standards mapping

No requirement-level mapping reviewed.

Limitations

Remote response authenticity is not established by local signing.

Only selected oracle inputs are replayed; their projection from the omitted raw body remains signer-attested.

Selective retest: seven declared views of one synthetic resource

Finding ID

finding-47ea938498ef7edb6494607a

Status

retest_verified

Execution record status

rejected

Interpretation

satisfied

Category

authorization_rule_violation

Rule digest

d4302c1e4ea6e69db715cb1860dd1a2487aa1a52343172d0cb7609bf7cf5aabb

Resource

invoice-A

Identity

peer

Case

target-4

Reproduction

GET /invoice/A?view=4 as peer; execute controls before this case. Use the retained source contract and environment/session credential references.

Expected checks

```
{"json_absent": ["/marker"], "status": [403]}
```

Observation

```
[{"body_complete": true, "controls_valid": true, "interpretation": "satisfied", "status": 403,
"verification_level": "captured_inputs_replayed"}]
```

Controls

actor, negative, owner

Evidence

dca8ec08ba1f1a6eb8e6d725916a0c20783145cb37b55f34fbecf44db3ff7357

Source report root

6f3bc05804641b66134abf65c356f5c08011a3c1d7a9eda330b7d46196e82751

Finding record digest

a56145a9a6165c486c17c1711092c7df19730cdcfc321205c2b540c64051db0f

Verification level

captured_inputs_replayed

Impact

Limited to the explicitly evaluated predicate; business impact requires review.

Remediation

Enforce the configured rule at the resource and response boundary; rerun this experiment with fresh controls.

Business risk

Not assessed by reviewer

CVSS 4.0

not_scored; vector: not supplied

Retest

```
[{"baseline_root": "9a9ea83b31031ee4c66bef9737ab671b151b69abe38eafd37d4de2c33434c3a3",  
"case_id": "target-4", "comparison_digest":  
"a3b207ec41722d49915c95384fa89d59f159873df4f119509a97c966e6b0550b", "comparison_sha256":  
"6665988aa0408f92d465ae23a549ada474d43332315f368f4839bc28ceaf3bac", "current_root":  
"6f3bc05804641b66134abf65c356f5c08011a3c1d7a9eda330b7d46196e82751", "finding_status":  
"fix_verified", "status": "resolved_check"}]
```

Standards mapping

No requirement-level mapping reviewed.

Limitations

Remote response authenticity is not established by local signing.

Only selected oracle inputs are replayed; their projection from the omitted raw body remains signer-attested.

Selective retest: seven declared views of one synthetic resource

Finding ID

finding-5c0e74f8b65f0c26dd5b3d6a

Status

retest_verified

Execution record status

rejected

Interpretation

satisfied

Category

authorization_rule_violation

Rule digest

d4302c1e4ea6e69db715cb1860dd1a2487aa1a52343172d0cb7609bf7cf5aabb

Resource

invoice-A

Identity

peer

Case

target-0

Reproduction

GET /invoice/A?view=0 as peer; execute controls before this case. Use the retained source contract and environment/session credential references.

Expected checks

```
{"json_absent": ["/marker"], "status": [403]}
```

Observation

```
[{"body_complete": true, "controls_valid": true, "interpretation": "satisfied", "status": 403, "verification_level": "captured_inputs_replayed"}]
```

Controls

actor, negative, owner

Evidence

687004de26b8bdf3981cfdc28d2aa6033b788dc2831dd66c7aaedc5677d5f51b

Source report root

6f3bc05804641b66134abf65c356f5c08011a3c1d7a9eda330b7d46196e82751

Finding record digest

7eb2cff3111dbf45c8eb6b3672f6a3e7c46bc89509325415546404d1a5e5e357

Verification level

captured_inputs_replayed

Impact

Limited to the explicitly evaluated predicate; business impact requires review.

Remediation

Enforce the configured rule at the resource and response boundary; rerun this experiment with fresh controls.

Business risk

Not assessed by reviewer

CVSS 4.0

not_scored; vector: not supplied

Retest

```
[{"baseline_root": "9a9ea83b31031ee4c66bef9737ab671b151b69abe38eafd37d4de2c33434c3a3", "case_id": "target-0", "comparison_digest": "a3b207ec41722d49915c95384fa89d59f159873df4f119509a97c966e6b0550b", "comparison_sha256": "6665988aa0408f92d465ae23a549ada474d43332315f368f4839bc28ceaf3bac", "current_root": "6f3bc05804641b66134abf65c356f5c08011a3c1d7a9eda330b7d46196e82751", "finding_status": "fix_verified", "status": "resolved_check"}]
```

Standards mapping

No requirement-level mapping reviewed.

Limitations

Remote response authenticity is not established by local signing.
Only selected oracle inputs are replayed; their projection from the omitted raw body remains signer-attested.

Selective retest: seven declared views of one synthetic resource

Finding ID

finding-91acb888cf876e88c941448b

Status

retest_verified

Execution record status

rejected

Interpretation

satisfied

Category

authorization_rule_violation

Rule digest

d4302c1e4ea6e69db715cb1860dd1a2487aa1a52343172d0cb7609bf7cf5aabb

Resource

invoice-A

Identity

peer

Case

target-6

Reproduction

GET /invoice/A?view=6 as peer; execute controls before this case. Use the retained source contract and environment/session credential references.

Expected checks

```
{"json_absent": ["/marker"], "status": [403]}
```

Observation

```
[{"body_complete": true, "controls_valid": true, "interpretation": "satisfied", "status": 403, "verification_level": "captured_inputs_replayed"}]
```

Controls

actor, negative, owner

Evidence

30e8f7ac1d174b3451d7561a9266389ae36eae09076aa673181c2d8889f0e5df

Source report root

6f3bc05804641b66134abf65c356f5c08011a3c1d7a9eda330b7d46196e82751

Finding record digest

a229d5a7ad4372c03ac28c1d8c30403ca004235d113a731e4213ec2b02f02775

Verification level

captured_inputs_replayed

Impact

Limited to the explicitly evaluated predicate; business impact requires review.

Remediation

Enforce the configured rule at the resource and response boundary; rerun this experiment with fresh controls.

Business risk

Not assessed by reviewer

CVSS 4.0

not_scored; vector: not supplied

Retest

```
[{"baseline_root": "9a9ea83b31031ee4c66bef9737ab671b151b69abe38eafd37d4de2c33434c3a3",  
"case_id": "target-6", "comparison_digest":  
"a3b207ec41722d49915c95384fa89d59f159873df4f119509a97c966e6b0550b", "comparison_sha256":  
"6665988aa0408f92d465ae23a549ada474d43332315f368f4839bc28ceaf3bac", "current_root":  
"6f3bc05804641b66134abf65c356f5c08011a3c1d7a9eda330b7d46196e82751", "finding_status":  
"fix_verified", "status": "resolved_check"}]
```

Standards mapping

No requirement-level mapping reviewed.

Limitations

Remote response authenticity is not established by local signing.

Only selected oracle inputs are replayed; their projection from the omitted raw body remains signer-attested.

Selective retest: seven declared views of one synthetic resource

Finding ID

finding-bfbf3a14c81af91f4f1e87ac

Status

retest_verified

Execution record status

rejected

Interpretation

satisfied

Category

authorization_rule_violation

Rule digest

d4302c1e4ea6e69db715cb1860dd1a2487aa1a52343172d0cb7609bf7cf5aabb

Resource

invoice-A

Identity

peer

Case

target-5

Reproduction

GET /invoice/A?view=5 as peer; execute controls before this case. Use the retained source contract and environment/session credential references.

Expected checks

```
{"json_absent": ["/marker"], "status": [403]}
```

Observation

```
[{"body_complete": true, "controls_valid": true, "interpretation": "satisfied", "status": 403, "verification_level": "captured_inputs_replayed"}]
```

Controls

actor, negative, owner

Evidence

6ed6f2926b0bf7cdf5b2cc9c4ba1741090b03448eaba1ea950a25072ec1017d7

Source report root

6f3bc05804641b66134abf65c356f5c08011a3c1d7a9eda330b7d46196e82751

Finding record digest

6cf0d6c4beb472a276848b02d1dee5b0be95fdb1313396efd0335092862a6943

Verification level

captured_inputs_replayed

Impact

Limited to the explicitly evaluated predicate; business impact requires review.

Remediation

Enforce the configured rule at the resource and response boundary; rerun this experiment with fresh controls.

Business risk

Not assessed by reviewer

CVSS 4.0

not_scored; vector: not supplied

Retest

```
[{"baseline_root": "9a9ea83b31031ee4c66bef9737ab671b151b69abe38eafd37d4de2c33434c3a3", "case_id": "target-5", "comparison_digest": "a3b207ec41722d49915c95384fa89d59f159873df4f119509a97c966e6b0550b", "comparison_sha256": "6665988aa0408f92d465ae23a549ada474d43332315f368f4839bc28ceaf3bac", "current_root": "6f3bc05804641b66134abf65c356f5c08011a3c1d7a9eda330b7d46196e82751", "finding_status": "fix_verified", "status": "resolved_check"}]
```

Standards mapping

No requirement-level mapping reviewed.

Limitations

Remote response authenticity is not established by local signing.

Only selected oracle inputs are replayed; their projection from the omitted raw body remains signer-attested.

Standards profile

API 2023

<https://api-security.owasp.org/editions/2023/en/0x11-t10/>

ASVS 5.0.0

<https://github.com/OWASP/ASVS/tree/v5.0.0>

CVSS 4.0

<https://www.first.org/cvss/v4.0/specification-document>

WSTG 4.2

<https://wstg.owasp.org/v4.2/>

Limitations and independent verification

Limitation

This is a scoped assessment, not certification or complete ASVS/WSTG/API coverage.

Limitation

Finding status, technical severity and business risk are separate dimensions.

Limitation

A restored configured check is not automatically a verified vulnerability fix.

Limitation

Retest omissions retain not_retested and historical evidence only.

Limitation

Signatures authenticate retained bytes and signing keys; they do not prove remote execution truth.

Limitation

Replayed oracle inputs are approved projections; their relationship to unavailable raw response bytes remains signer-attested.

Limitation

The standalone verifier provides integrity_only; semantic verification requires AuthzLedger and the pinned report renderer.

Limitation

Seven explicit query variants share one synthetic resource, identity and rule.

Limitation

The 90 remaining baseline cases are historical, not evidence of a current fix.

Limitation

100 to 10 compares dispatched requests within this fixture; it is not a general speedup benchmark.

Limitation

Server receipts are local measurements by this runner, not third-party execution attestations.

Limitation

Setup, cleanup, replay, reduction, PDP, advisory and state probes make no HTTP requests here.

Verify

Obtain the public-key fingerprint through an independent trusted channel. Run: `python3 -I verify_bundle.py PACKAGE --public-key TRUSTED.pem`. The package manifest supplies the signer fingerprint. Then run AuthzLedger verify-bundle for retained evidence and exact report semantics. Never trust a key solely because it is inside the package.